

7. Arquitectura de Seguridad

7.1 Principios de Seguridad

Principio	Aplicación
Defense in Depth	Múltiples capas de seguridad (edge, red, app,
Least Privilege	IAM roles con permisos mínimos necesarios
Zero Trust	Verificar siempre, no confiar por defecto
Encrypt Everything	Cifrado en tránsito y reposo sin excepción
Audit Everything	Registro inmutable de todas las acciones

7.2 Capas de Seguridad

Capa 1: Identidad y Acceso

Componente	Servicio	Función
Identity Provider	AWS Cognito	Autenticación OAuth2/OIDC, MFA
Federación	Active Directory	Integración con directorio corporativo
Autorización	IAM + RBAC	Control de acceso basado en roles
Tokens	JWT (RS256)	Tokens de corta duración (15 min access, 7 dí
MFA	Cognito MFA	Obligatorio para analistas y gerentes

Roles definidos

Rol	Permisos
Analista de Campañas	Crear, simular, ejecutar campañas. Ver dashbo
Gerente de Riesgo	Aprobar campañas, configurar apetito de riesg
Administrador	Gestión de reglas, configuración de sistema,
Sistema (Service Account)	Integración entre servicios, acceso a datos

Capa 2: Protección de Borde (Edge)

Componente	Servicio	Función
DNS Security	Route 53 + DNSSEC	Protección contra DNS spoofing
CDN + DDoS	CloudFront + Shield	Distribución y protección DDoS
WAF	AWS WAF	Reglas contra OWASP Top 10, rate limiting, ge
Bot Protection	WAF Bot Control	Detección y bloqueo de bots

Reglas WAF

Regla	Descripción
Rate Limiting	Max 1000 req/min por IP
SQL Injection	Bloqueo de patrones SQLi

XSS	Bloqueo de cross-site scripting
Geo-blocking	Solo tráfico desde Colombia (para portal inte
IP Whitelist	IPs corporativas para acceso administrativo

Capa 3: Seguridad de Red

Componente	Servicio	Función
Aislamiento	VPC	Red privada virtual para Lambdas que acceden
Subnets	Private Subnets	Lambdas en subnets privadas sin acceso direct
Endpoints	VPC Endpoints	Acceso a DynamoDB y S3 sin salir a internet
Conectividad Legacy	VPN Site-to-Site	Conexión cifrada a sistemas on-premise
Conectividad GCP	Private Connect	Conexión privada AWS-GCP sin internet público

Capa 4: Seguridad de Aplicación

Control	Implementación
Validación de entrada	JSON Schema validation en API Gateway
Sanitización	Lambda middleware para sanitizar inputs
CORS	Configurado en API Gateway (solo dominios aut
Content Security Policy	Headers de seguridad en CloudFront
Dependency scanning	Snyk/Dependabot en CI/CD
SAST	SonarQube en pipeline de CI
Secrets management	AWS Secrets Manager (rotación automática)

Capa 5: Seguridad de Datos

Control	Implementación
Cifrado en reposo	AES-256 con AWS KMS (Customer Managed Keys)
Cifrado en tránsito	TLS 1.3 en todas las comunicaciones
Enmascaramiento PII	Datos sensibles enmascarados en logs y ambien
Tokenización	Números de cuenta tokenizados en tránsito
Backup cifrado	Backups cifrados con llaves separadas
Data classification	Etiquetado de datos (público, interno, confid
Retención	Políticas de retención según regulación (5 añ
Derecho al olvido	Proceso de eliminación de datos personales (H

Capa 6: Detección y Respuesta

Control	Servicio	Función
SIEM	CloudWatch + Security Hub	Correlación de eventos de seguridad
Threat Detection	GuardDuty	Detección de amenazas y comportamiento anómalo
Config Compliance	AWS Config	Verificación continua de compliance
Vulnerability Scan	Inspector	Escaneo de vulnerabilidades en código
Incident Response	Runbooks automatizados	Respuesta automática a incidentes comunes
Forensics	CloudTrail + VPC Flow Logs	Evidencia para investigación

7.3 Seguridad en Comunicación entre Nubes (AWS ? GCP)

Diagrama de Flujo Seguro

[Diagrama - ver archivo PNG adjunto]

Controles Cross-Cloud

Aspecto	AWS	GCP	Protocolo
Autenticación	IAM Role + STS	Service Account + Workload Identity	OAuth2 tokens
Transporte	TLS 1.3	TLS 1.3	mTLS para service-to-service
Red	VPC + Private Link	VPC + Private Service Connect	No internet público
Cifrado datos	KMS encrypt antes de enviar	KMS decrypt al recibir	Doble cifrado
Auditoría	CloudTrail	Cloud Audit Logs	Logs correlacionados
Rotación credenciales	STS tokens (1h max)	Short-lived tokens (1h)	Automática

7.4 Seguridad en Integración con Sistemas Legacy

Sistema	Protocolo	Autenticación	Cifrado
Core Bancario (vía ESB)	SOAP/REST sobre HTTPS	Certificados mutuos (mTLS)	TLS 1.2+
CRM Siebel (vía ESB)	SOAP sobre HTTPS	mTLS + API Key	TLS 1.2+
Sistema de Créditos	REST HTTPS	mTLS	TLS 1.2+
Centrales de Riesgo	REST HTTPS	API Key + OAuth2	TLS 1.3
Telecomunicaciones	REST HTTPS	OAuth2 Client Credentials	TLS 1.3
Proveedor Notificaciones	REST HTTPS	API Key + HMAC	TLS 1.3
PSE (ACH Colombia)	HTTPS	Certificados digitales	TLS 1.2+

7.5 Seguridad en Integración con PSE (ATH Colombia)

Control	Implementación
Autenticación	Certificados digitales emitidos por ACH Colom
Integridad	Firma digital de transacciones (SHA-256)
No repudio	Logs firmados digitalmente
Cifrado	TLS 1.2+ con cipher suites aprobados por ACH
Validación	Verificación de hash de respuesta PSE
Timeout	Transacciones con timeout de 15 minutos
Idempotencia	ID único por transacción para evitar duplicad
Normativa	Cumplimiento de protocolos de seguridad y cib
Monitoreo	Alertas en tiempo real ante transacciones sos
Conciliación	Proceso de compensación automático con archiv

7.6 Seguridad en Integración con DECEVAL

Control	Implementación
Autenticación	Certificados digitales + API Key

Cifrado	TLS 1.3 end-to-end
Firma digital	Pagarés firmados digitalmente con certificado
No repudio	Registro inmutable de firma en DECEVAL
Validación	Verificación de identidad del firmante (vincu
Auditoría	Log de todas las operaciones de desmaterializ

7.6 Compliance y Regulación

Regulación	Aplicación	Controles
Habeas Data (Ley 1581/2012)	Datos personales de clientes	Consentimiento, acceso, rectificación, elimin
Circular 007 SFC	Seguridad en canales electrónicos	MFA, cifrado, monitoreo de fraude
PCI DSS (si aplica)	Datos de tarjetas	Segmentación, cifrado, acceso restringido
SOX	Controles financieros	Audit trail, segregación de funciones
ISO 27001	Gestión de seguridad	SGSI, gestión de riesgos, mejora continua

7.7 Diagrama de Seguridad (Referencia Visual)

Ver diagrama: `diagramas/to-be/CAM-TOBE-04-seguridad.png`

Las capas de seguridad se aplican transversalmente a todos los componentes de la arquitectura, desde el borde (WAF, CloudFront) hasta los datos (KMS, cifrado en reposo), pasando por la aplicación (Cognito, JWT, validación) y la plataforma (VPC, Security Groups, Secrets Manager).